

- d. Escalate issues that cannot be resolved in a timely manner to the appropriate level of management.
 - e. Prioritize and track issues through final resolution.
 - f. Analyze results and issues to determine whether problems can be traced to a common source.
 - g. Document recommendations for future exercise and tests.
29. Verify that corrective actions have been implemented and that retesting occurs in a timely fashion to address deficiencies in meeting the entity's objectives.
30. Verify that test results are used to update the business continuity processes, enhance future testing, and evaluate whether risk mitigation strategies should be adjusted.

Objective 11: Determine whether management continuously measures the progress and assesses the effectiveness of BCM and uses the information to improve the BCM process. (VIII, "[Maintenance and Improvement](#)")

1. Determine whether management reviews and updates the business continuity program to reflect the current environment. Triggers that prompt maintenance and improvement of the BCM may include the following:
 - a. Changes in enterprise strategies.
 - b. New or reconfigured products, services, or infrastructure.
 - c. Changes in products and services offered by third-party service providers.
 - d. Deficiencies identified in third-party service provider BCM processes.
 - e. New legislation, regulatory requirements, or resilience practices.
 - f. Results of operational metric analysis (e.g., key risk indications, key performance indicators).
 - g. Early warning indicators that may identify potential continuity events, crises, or incidents (e.g., frequency and severity of storms, heightened cyber attack activity, or increases in customer service calls).
 - h. Variances between budgeted and actual BCM expenses.
 - i. Results from exercises and tests and lessons learned.
 - j. Changes in the threat landscape (e.g., new capabilities, intent of threat actors).
 - k. Recommendations (e.g., from audits, vulnerability assessments, and penetration tests, including those involving the use of advanced cybersecurity analysis and assessments).
2. Determine whether management has documented, analyzed, and reviewed lessons learned from adverse events. Documented procedures for incorporating lessons learned may include:
 - a. Identifying the failure(s).
 - b. Determining the cause(s).
 - c. Evaluating potential solutions.
 - d. Implementing corrective actions as appropriate.
 - e. Recording and reviewing corrective actions taken.

3. Verify that management documents, tracks, and resolves any changes when updating the BCP and the exercise and testing program(s). Furthermore, verify that management maintains appropriate version control of key BCM documents.
4. Determine whether management maintains backup copies of relevant BCM documentation in the event that the primary repository becomes inaccessible.

Objective 12: Determine whether the board has established expectations for BCM reporting. (IX, “[Board Reporting](#)”)

1. Review board minutes to determine whether management periodically reports to the board on the status of BCM.
 - a. Determine whether reports include a written BCM presentation, including the BIA, risk assessment, BCP, exercise and test results, and identified issues.
 - b. Determine whether management provides the board with regular strategy updates based on changes in personnel, roles and responsibilities, and business operations.
 - c. Verify that management documents the reasons (e.g., cost and service level) for choosing recovery alternatives and why they are appropriate based on the entity’s risk profile and complexity.
 - d. Assess whether the board provides a credible challenge to management, when appropriate.

Objective 13: Discuss corrective action and communicate findings.

1. Review preliminary conclusions with the examiner-in-charge regarding the following:
 - a. Apparent violations of laws and regulations.
 - b. Significant issues warranting inclusion in the report of examination.
 - c. Proposed Uniform Rating System for IT (URSIT) management component rating and the potential impact of the examiner’s conclusions on composite or other URSIT component ratings.
 - d. Potential impact of the examiner’s conclusions on the entity’s risk assessment(s).
2. Discuss findings with management and obtain proposed corrective action for significant deficiencies.
3. Document conclusions in a memorandum to the examiner-in-charge that provides report-ready comments for all relevant sections of the report of examination and clarifying guidance to future examiners.
4. Organize work papers to show clear support for significant findings by examination objective.

Appendix B: Glossary

The purpose of the glossary is to define technical terms used in the *FFIEC IT Examination Handbook* booklets in the context of supervisory activities for the entities over which FFIEC members have supervisory authority. The FFIEC members strive to align terminology in the glossary with appropriate authoritative standards, including the *NIST Computer Security Resource Center Glossary* (NIST Glossary) as the primary source for cyber-related definitions, as appropriate. FFIEC members employed the following process to select, modify, or develop definitions.

When a NIST definition existed:

- If NIST had a defined term and modifications to the definition were unnecessary, the FFIEC members included the NIST definition in this glossary. When multiple NIST definitions were available for the same term, the FFIEC members selected a definition for supervisory purposes.
- If NIST had a defined term, but the definition needed additional clarity for supervisory purposes to assist with the identification of safety and soundness and enterprise risks related to IT, the FFIEC members included both the NIST definition and the FFIEC-adapted definition. Definitions of this nature are labeled “FFIEC Adapted for Supervisory Purposes” in this glossary’s source column.

When a NIST definition did not exist or the definition was not appropriate for supervisory purposes:

- If NIST did not have a defined term, but there was an appropriate authoritative third-party source (e.g., the International Organization for Standardization (ISO) Glossary), the FFIEC members included that authoritative definition.
- If NIST did not have a defined term and there was not an appropriate authoritative third-party source, the FFIEC members developed a definition for supervisory purposes. Definitions of this nature are labeled “FFIEC Developed for Supervisory Purposes” in this glossary’s source column.

Note: Due to the constantly evolving nature of IT and its associated risks, the FFIEC members may update definitions to maintain alignment with other government agencies and the financial services industry.

Term	Definition	Source
A		
Application programming interface (API)	A system access point or library function that has a well-defined syntax and is accessible from application programs or user code to provide well-defined functionality.	NIST Glossary
	Software code that allows two or more programs to communicate with each other.	FFIEC Adapted for Supervisory Purposes

Asynchronous replication	Data is first written to the primary storage area (store) and then copied to the secondary storage area (forward) at predefined intervals, which is useful over smaller bandwidth connections and longer distances where latency could occur.	FFIEC Developed for Supervisory Purposes
B		
Business continuity	The capability of the organization to continue delivery of products or services at acceptable predefined levels following a disruption.	ISO 22300:2018(en)
Business continuity management (BCM)	The process for management to oversee and implement resilience, continuity, and response capabilities to safeguard employees, customers, and products and services.	FFIEC Developed for Supervisory Purposes
Business continuity plan (BCP)	The documentation of a predetermined set of instructions or procedures that describe how an organization's mission/business processes will be sustained during and after a significant disruption.	NIST Glossary
	A comprehensive written plan(s) to maintain or resume business in the event of a disruption.	FFIEC Adapted for Supervisory Purposes
Business impact analysis (BIA)	An analysis of an information system's requirements, functions, and interdependencies used to characterize system contingency requirements and priorities in the event of a significant disruption.	NIST Glossary
	Management's analysis of an entity's requirements, functions, and interdependencies used to characterize contingency needs and priorities in the event of a disruption.	FFIEC Adapted for Supervisory Purposes
C		
Cold site	A backup facility that has the necessary electrical and physical components of a computer facility, but does not have the computer equipment in place. The site is ready to receive the necessary replacement computer equipment in the event that the user has to move from their main computing location to an alternate site.	NIST Glossary
Contingency plan	A plan that is maintained for disaster response, backup operations, and post-disaster recovery to ensure the availability of critical resources and to facilitate the continuity of operations in an emergency situation.	NIST Glossary
Crisis	Abnormal and unstable situation that threatens the organization's strategic objectives, reputation or viability.	Business Continuity Institute Disaster Recovery Journal Glossary
Crisis management	The process of managing an entity's preparedness, mitigation response, continuity, or recovery in the event of an unexpected significant disruption, incident, or emergency.	FFIEC Developed for Supervisory Purposes
Critical financial markets	Financial markets whose operations are critical to the economy. Critical financial markets provide the means for financial institutions to adjust their cash and securities positions and those of their customers in order to manage liquidity, market, and other risks to their organizations. Critical financial markets also provide support for the provision of a wide range of financial services to businesses and consumers in the United States and support the implementation of monetary policy. Examples of critical financial markets include federal funds, foreign	FFIEC Developed for Supervisory Purposes

	exchange, and commercial paper; U.S. government and agency securities; and corporate debt and equity securities.	
D		
Data	A representation of information as stored or transmitted.	NIST Glossary
	A physical or digital representation of information processed, stored (at rest), or transmitted (in transit).	FFIEC Adapted for Supervisory Purposes
Data center	A facility that houses virtual and/or physical information technology infrastructure(s) (e.g., computer, server, and networking systems and components) designed to store, process, and serve large amounts of data in support of an entity's strategic and business objectives. A data center may be a dedicated facility or an area or room, that contains computer, server and networking systems and components, and may be private or shared (e.g., a co-location facility).	FFIEC Developed for Supervisory Purposes
Data mirroring	The act of copying data from a database at a primary location to a database at a secondary location in or near real time.	FFIEC Developed for Supervisory Purposes
Data replication	The process of copying data, usually with the objective of maintaining identical sets of data in separate locations.	FFIEC Developed for Supervisory Purposes
Data synchronization	The simultaneous comparison and reconciliation of interdependent data files, to ensure that the files contain the same information.	FFIEC Developed for Supervisory Purposes
Database	A repository of information or data, which may or may not be a traditional relational database system.	NIST Glossary
	A repository of information or data organized to be accessed, managed, and updated.	FFIEC Adapted for Supervisory Purposes
Disaster	Situation where widespread human, material, economic, or environmental losses have occurred, which exceeded the ability of the affected organization, community, or society to respond and recover using its own resources.	ISO 22300:2018(en)
Disaster recovery	The process, policies, and procedures related to preparing for recovery or continuation of technology infrastructure, systems, and applications, which are vital to an organization after a disaster or outage. Disaster recovery focuses on the information or technology systems that support business functions, as opposed to business continuity, which involves planning for keeping all aspects of a business functioning in the midst of disruptive events. Disaster recovery is a subset of business continuity.	Business Continuity Institute Disaster Recovery Journal Glossary
Disruption	An unplanned event that causes the general system or major application to be inoperable for an unacceptable length of time (e.g., minor or extended power outage, extended unavailable network, or equipment or facility damage or destruction).	NIST Glossary
	An anticipated or unplanned event that causes operations to degrade or fail for an unacceptable length of time	FFIEC Adapted for Supervisory Purposes

E		
Emergency management	See crisis management.	
Emergency response	Actions taken in response to a disaster warning or alert to minimize or contain the eventual negative effects, and those taken to save and preserve lives and provide basic services in the immediate aftermath of a disaster impact, for as long as an emergency situation prevails.	Business Continuity Institute Disaster Recovery Journal Glossary
Event	Occurrence or change of a particular set of circumstances.	NIST Glossary
	An occurrence or change in circumstances that may affect operations. An event can be physical, cyber, or a combination of both	FFIEC Developed for Supervisory Purposes
Exercise	A simulation of an emergency designed to validate the viability of one or more aspects of an IT plan.	NIST Glossary
	A task or activity done to practice or test a procedure. There are many different types of exercises, depending on the intended goals and objectives. An exercise may involve performing duties in a simulated environment and can be discussion-based or simulation-based.	FFIEC Adapted for Supervisory Purposes
F		
Failover	The capability to switch over automatically (typically without human intervention or warning) to a redundant or standby information system upon the failure or abnormal termination of the previously active system.	NIST Glossary
Full-scale exercise	A simulation involving a full use of available resources (e.g., hardware, software, personnel, communications, utilities, and processing from an alternate site) at the same time.	FFIEC Developed for Supervisory Purposes
Functional testing	Testing that verifies that an implementation of some function operates correctly.	NIST Glossary
H		
High availability	A failover feature to ensure availability during device or component interruptions.	NIST Glossary
	Ability of a system to be continuously operational for a desirably long length of time and to maintain a minimum amount of downtime during device or component interruptions. Availability can be measured relative to "100% uptime" or "never failing."	FFIEC Adapted for Supervisory Purposes
Hot site	A fully operational off-site data processing facility equipped with hardware and software, to be used in the event of an information system disruption.	NIST Glossary
I		
Incident	An occurrence that actually or potentially jeopardizes the confidentiality, integrity, or availability of a system or the information the system processes, stores, or transmits or that constitutes a violation or imminent threat of violation of security policies, security procedures, or acceptable use policies.	NIST Glossary

Incident management	The process of identifying, analyzing, and correcting disruptions to operations and preventing future recurrences. The goal of incident management is to limit the disruption and restore operations as quickly as possible.	FFIEC Developed for Supervisory Purposes
Incident response	The response of an organization to a disaster or other significant event that may significantly impact the organization, its people, or its ability to function productively. An incident response may include evacuation of a facility, initiating a disaster recovery plan, performing damage assessment, and any other measures necessary to bring an organization to a more stable status.	Business Continuity Institute Disaster Recovery Journal Glossary
Infrastructure	System of facilities, equipment, and services needed for the operation of an organization.	ISO 22300:2018(en)
Integrated exercise	A simulation to test the effectiveness of the continuity plans for a business line or major function that incorporates more than one component or module, including external dependencies.	FFIEC Developed for Supervisory Purposes
Interdependencies	When two or more departments, processes, functions, or third-party providers interact to successfully complete a task, business function, or process.	FFIEC Developed for Supervisory Purposes
L		
Last mile	Communications technology that bridges the transmission distance between the telecommunication service provider and the entity.	FFIEC Developed for Supervisory Purposes
Latency	Time delay in processing voice packets.	NIST Glossary
	Time delay in processing voice and data packets.	FFIEC Adapted for Supervisory Purposes
Limited-scale exercise	A simulation involving applicable resources (personnel and systems) to recover targeted business processes.	FFIEC Developed for Supervisory Purposes
M		
Maximum tolerable downtime (MTD)	The amount of time mission/business process can be disrupted without causing significant harm to the organization's mission.	NIST Glossary
	The total amount of time the system owner or authorizing official is willing to accept for a business process disruption, including all impact considerations.	FFIEC Adapted for Supervisory Purposes
N		
Network backbone	The main communication channel of a network that interconnects one or more network segments and provides a path for the exchange of data between devices. A backbone can span any geographic area.	FFIEC Developed for Supervisory Purposes
O		
Operational resilience	The ability of systems to resist, absorb, and recover from or adapt to an adverse occurrence during operation that may cause harm, destruction, or loss of ability to perform mission-related functions.	NIST Glossary
	The ability of an entity's personnel, systems, telecommunications networks, activities, or processes to resist, absorb, and recover from or	FFIEC Adapted for Supervisory Purposes

	adapt to an incident that may cause harm, destruction, or loss of ability to perform mission-related functions.	
Outage	The interruption of systems, infrastructure, support services, or essential business functions, which may result in the entity's inability to provide services for some period of time. The amount of time lost from an outage may result in downtime. Conversely, downtime may cause an outage.	FFIEC Developed for Supervisory Purposes
Outsourcing	The practice of contracting through a formal agreement with a third party(ies) to perform services, functions, or support that might otherwise be conducted in-house.	FFIEC Developed for Supervisory Purposes
R		
Reciprocal agreement	An agreement that allows two organizations to back up each other.	NIST Glossary
	An agreement that allows two entities (or two internal business groups) with compatible systems and functionality that allows each one to recover at the other's location.	FFIEC Adapted for Supervisory Purposes
Recovery point objective (RPO)	The point in time to which data must be recovered after an outage.	NIST Glossary
	The point in time to which data used by an activity is restored to enable the resumption of business functions. The RPO is expressed backward in time from the point of disruption and can be specified in increments of time (e.g., minutes, hours, or days).	FFIEC Adapted for Supervisory Purposes
Recovery time objective (RTO)	The overall length of time an information system's components can be in the recovery phase before negatively impacting the organization's mission or mission/business processes.	NIST Glossary
Remote access	Access to an organizational information system by a user (or an information system) communicating through an external, non-organization-controlled network (e.g., the Internet).	NIST Glossary
Resilience	The ability to prepare for and adapt to changing conditions and withstand and recover rapidly from disruptions. Resilience includes the ability to withstand and recover from deliberate attacks, accidents, or naturally occurring threats or incidents.	NIST Glossary
S		
Scenario	A sequential, narrative account of a hypothetical incident that provides the catalyst for the exercise and is intended to introduce situations that will inspire responses and thus allow demonstration of the exercise objectives.	NIST Glossary
Service level agreement	Defines the specific responsibilities of the service provider and sets the customer expectations.	NIST Glossary
	A formal agreement between two parties that records: a common understanding about products or services to be delivered, priorities, responsibilities, guarantees, and warranties between the parties. In addition, the agreement describes the nature, quality, security, availability, scope, and timeliness of delivery and response of the parties, the point(s) of contact for end-user problems, and the metrics by which the effectiveness of the process is monitored and approved, and may include other measurable objectives. The agreement should cover not only expected day-to-day situations, but also unexpected or adverse events, as the need for the service may vary.	FFIEC Adapted for Supervisory Purposes

Supply chain risk management	The implementation of processes, tools, or techniques to minimize the adverse impact of attacks that allow the adversary to utilize implants or other vulnerabilities inserted prior to installation in order to infiltrate data, or manipulate information technology hardware, software, operating systems, peripherals (information technology products) or services at any point during the life cycle.	NIST Glossary
	The implementation of processes, tools, or techniques to minimize the adverse impact of attacks that allow the adversary to exploit vulnerabilities inserted prior to installation. This is done in order to infiltrate data, or manipulate information technology hardware, software, operating systems, peripherals (information technology products) or services at any point during the supply chain (e.g., initial production, packaging, handling, storage, transport, mission operation, and disposal).	FFIEC Adapted for Supervisory Purposes
Synchronous replication	Data is written to both primary and secondary storage areas at the same time to ensure that multiple copies of the data are current and identical. This method is used for critical business functions where latency is unacceptable, and little or no data loss can be tolerated.	FFIEC Developed for Supervisory Purposes
T		
Tabletop exercise	A discussion-based exercise where personnel with roles and responsibilities in a particular IT plan meet in a classroom setting or in breakout groups to validate the content of the plan by discussing their roles during an emergency and their responses to a particular emergency situation. A facilitator initiates the discussion by presenting a scenario and asking questions based on the scenario.	NIST Glossary
	A discussion-based exercise where personnel meet in a classroom setting or in breakout groups to validate a component(s) of the business continuity plan(s) by discussing their roles and responsibilities. A facilitator initiates the discussion by presenting a scenario and asking questions based on the scenario.	FFIEC Adapted for Supervisory Purposes
Test	An evaluation tool that uses quantifiable metrics to validate the operability of a system or system component in an operational environment specified in an IT plan.	NIST Glossary
	A type of exercise intended to verify the quality, performance, or reliability of system resilience in an operational environment.	FFIEC Adapted for Supervisory Purposes
Threat intelligence	Threat information that has been aggregated, transformed, analyzed, interpreted, or enriched to provide the necessary context for decision-making processes.	NIST Glossary
Trigger	An event that causes the system to initiate a response. Note: Also known as a triggering event.	NIST Glossary
	An event that prompts a response from management or an automated system. Also known as a triggering event.	FFIEC Adapted for Supervisory Purposes
W		
Warm site	An environmentally conditioned work space that is partially equipped with information systems and telecommunications equipment to support relocated operations in the event of a significant disruption.	NIST Glossary

Appendix C: Abbreviations

ATM	automated teller machine
BCM	business continuity management
BCP	business continuity plan
BIA	business impact analysis
CA Letter	Consumer Affairs Letter
CAPS	Cyber-Attack Against Payment Systems
CDC	Centers for Disease Control and Prevention
CFPB	Consumer Financial Protection Bureau
CFR	Code of Federal Regulations
COSO	Committee of Sponsoring Organizations of the Treadway Commission
DDoS	distributed denial of service
DHS	U.S. Department of Homeland Security
DRaaS	disaster recovery as a service
ERM	enterprise risk management
FBIIC	Financial and Banking Information Infrastructure Committee
FDIC	Federal Deposit Insurance Corporation
FFIEC	Federal Financial Institutions Examination Council
FIL	Financial Institution Letter
FRB	Board of Governors of the Federal Reserve System
FS-ISAC	Financial Services Information Sharing and Analysis Center
FSARC	Financial Systemic Analysis & Resilience Center
FSSCC	Financial Services Sector Coordinating Council
GETS	Government Emergency Telecommunications Service
IIA	Institute of Internal Auditors
ISO	International Organization for Standards
IT	information technology
<i>IT Handbook</i>	<i>FFIEC Information Technology Examination Handbook</i>
MTD	maximum tolerable downtime
NCUA	National Credit Union Administration
NIST	National Institute of Standards and Technology
OCC	Office of the Comptroller of the Currency
ODNI	Office of the Director of National Intelligence
RPO	recovery point objective
RTO	recovery time objective
SLA	service-level agreement
SLC	State Liaison Committee
SOC	systems and organization control
SR Letter	Supervision and Regulation Letter
SSAE	Statement on Standards for Attestation Engagement
TSP	Telecommunications Service Priority
URSIT	Uniform Rating System for Information Technology
USC	United States Code
WPS	Wireless Priority Service Program